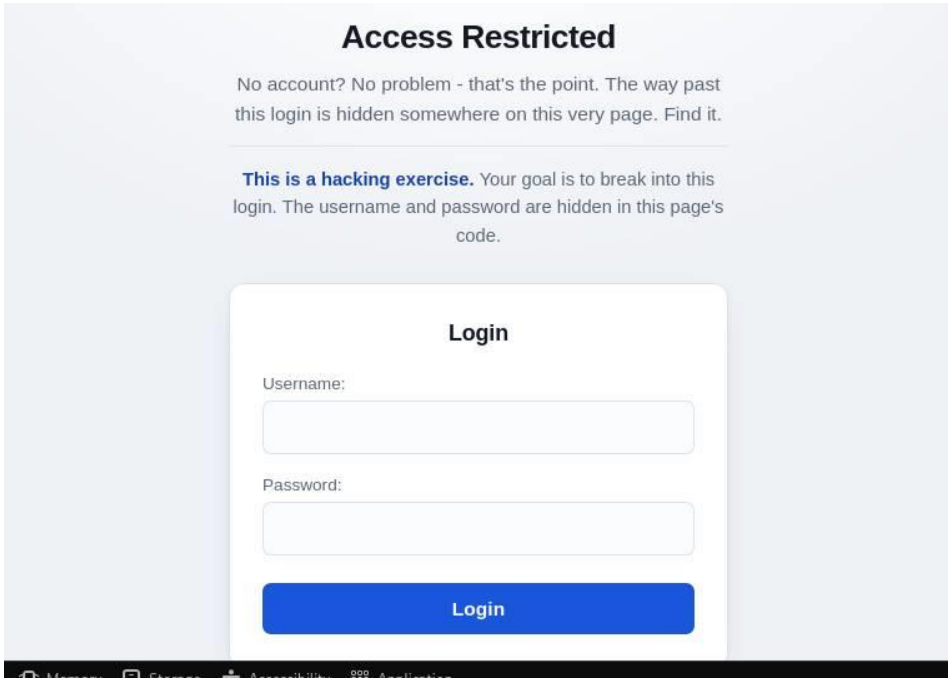
Lab Overview

- **Platform:** HackerDNA
- **Difficulty:** Very Easy
- **Category:** Web & API Security
- **Objective:** Perform a client-side authentication bypass by inspecting the source code and finding the hardcoded credentials required to log in and capture the flag.

Reconnaissance & Initial Access

1. **Accessing the Portal:** Navigating to the lab URL presents an **Access Restricted** login page. The prompt explicitly notes that the credentials needed to pass this login are hidden somewhere within the page's code.

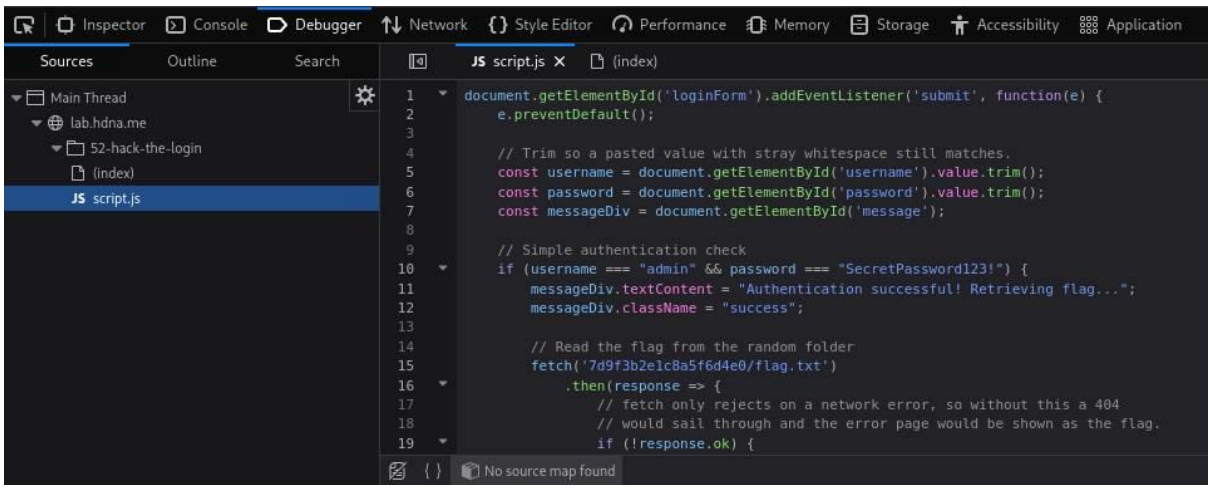


2. **Inspecting the Source:** Opening the browser's Developer Tools (`F12`) and looking at the Sources/Debugger tab reveals the loaded JavaScript files, specifically `script.js`.

Vulnerability Analysis

Step 1: Finding Hardcoded Credentials in Client-Side Code

By examining `script.js`, we can see how the application handles authentication:
JavaScript



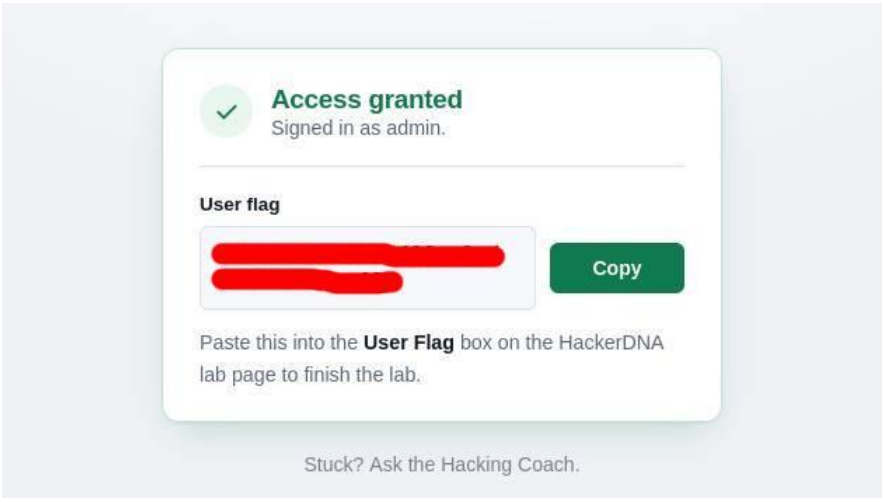
The application performs a purely **client-side authentication check**, comparing the input directly against hardcoded strings (`admin` / `SecretPassword123!`) in the frontend JavaScript code rather than verifying credentials securely on a server.

Exploitation (Authentication Bypass)

1. **Entering Credentials:** Using the discovered credentials from the source code:

- **Credentials:** `admin/SecretPassword123!`

2. **Submitting the Form:** Entering these values into the login form triggers the JavaScript validation block, passes the client-side check, and fetches the flag successfully.



Remediation & Prevention

To fix client-side authentication bypass vulnerabilities:

- **Server-Side Authentication:** Never handle credential validation or password comparisons in client-side code (JavaScript). All authentication checks must be performed securely on the server side against a properly hashed and salted database.

- **API Security:** Protect sensitive resources and files (such as flag endpoints or admin data) behind a robust server-side session or token-based authorization mechanism, ensuring unauthorized users cannot access them simply by altering frontend logic or bypassing the login screen.